UNIVERSITAS SILIWANGI
FAKULTAS TEKNIK
PROGRAM STUDI INFORMATIKA

LAPORAN KEGIATAN BLOCKCHAIN – UJIAN AKHIR SEMESTER (UAS)

Tahun Akademik 2026/2027 Semester Ganjil

Identitas	Isian
Jenis laporan	UAS individu
Judul kasus atau proyek	CertiChain – Registri Sertifikat Digital Berbasis Smart Contract (DApp)
Nama dan NPM	[Isi nama dan NPM]
Kelas / semester	[Isi kelas] / 7
Mata kuliah / kode	Blockchain / KP70067008
Dosen pengampu	Dr. Ir. Nur Widiyasono, M.Kom.
Tanggal kegiatan	21 Oktober 2026 (pengujian, audit, dan deployment pada local network)

Ringkasan Kegiatan

Laporan ini membahas pertanyaan utama UAS: apakah solusi blockchain yang dibangun layak, aman, teruji, dapat direproduksi, dan memiliki arsitektur serta tata kelola yang dapat dipertanggungjawabkan. Kasus yang dikerjakan adalah CertiChain, registri sertifikat digital yang dipakai bersama oleh beberapa penerbit. Hanya hash dokumen yang disimpan di blockchain, sedangkan berkas dan data pribadi tetap berada di luar rantai. Kontrak ditulis dengan Solidity 0.8.24, diuji dengan Hardhat, dan dijalankan pada local blockchain tanpa aset kripto nyata.

Penulis merancang arsitektur dan model data, membuat kontrak dengan pembagian peran admin dan issuer, lalu menguji kontrak dengan 31 unit test. Audit dilakukan pada versi awal kontrak yang sengaja dibuat rentan, menggunakan threat model, enam PoC eksploit, dan analisis statis Slither. Hasilnya tujuh temuan: enam diperbaiki dan diverifikasi ulang, satu bersifat informasional. Seluruh 37 tes lulus dan coverage kontrak utama mencapai 100% untuk statement, function, dan line.

Untuk penggunaan nyata, penulis merekomendasikan blockchain permissioned berbasis EVM yang dikelola konsorsium penerbit. Keterbatasan pekerjaan ini: audit dilakukan sendiri tanpa fuzzing, frontend belum diuji otomatis di peramban, dan data yang dipakai hanya simulasi.

1 Pendahuluan

1.1 Latar belakang dan tujuan

Sertifikat dan ijazah masih sering beredar sebagai PDF atau kertas yang mudah dipalsukan. Pihak yang ingin memastikan keasliannya biasanya harus menghubungi penerbit secara manual, dan prosesnya lambat. Bila penerbitnya banyak dan tidak saling percaya, tidak ada catatan bersama yang dapat diaudit oleh semua pihak.

Kasus yang diangkat adalah organisasi dengan beberapa penerbit yang membutuhkan pencatatan penerbitan dan pencabutan sertifikat, jejak audit yang kuat, kontrol akses yang jelas, dan verifikasi publik yang murah tanpa membuka data pribadi pemegang sertifikat.

Laporan ini menjawab empat pertanyaan. Pertama, apakah pembagian data on-chain dan off-chain serta kontrol akses sudah sesuai kebutuhan. Kedua, apakah kontrak dapat diuji, di-debug, di-deploy, dan dipanggil dari client. Ketiga, apakah kerentanan umum dapat ditemukan, diperbaiki, dan dibuktikan. Keempat, apakah public blockchain memang pilihan terbaik dibandingkan blockchain permissioned atau database biasa.

Proyek dianggap berhasil bila kontrak dapat dikompilasi, semua tes lulus, setiap temuan audit memiliki bukti dan retest, alur dari stake sampai pencabutan berjalan di local network, dan langkah reproduksinya terdokumentasi.

1.2 Ruang lingkup

Ruang lingkup mencakup satu kontrak utama (CertiChain.sol) beserta interface, library, dan modul akses; satu versi awal yang rentan (CertiChainV1.sol) sebagai bahan audit; dua kontrak tiruan untuk pengujian; skrip deploy dan integrasi; serta frontend web sederhana. Jaringan yang dipakai adalah Hardhat local network dengan chain ID 31337 dan akun uji bawaan. Datanya berupa hash dari teks sertifikat contoh dan alamat akun uji, tanpa data pribadi nyata.

Batasannya: tidak ada aset kripto nyata, private key utama, seed phrase pribadi, atau jaringan produksi. Penyimpanan berkas PDF di luar rantai hanya disimulasikan, tidak ada oracle eksternal, dan frontend belum diuji otomatis di peramban.

2 Data, Alat, dan Reproduksibilitas

Komponen	Keterangan / rujukan
Dataset atau use case	Use case: registri sertifikat digital CertiChain. Data simulasi: hash keccak256 dari teks sertifikat contoh dan alamat akun uji Hardhat. Versi 1.0.0, 21 Oktober 2026.
Lingkungan	Linux (Ubuntu 24), Node.js v22.22.2, npm 10.9.7. Hardhat node lokal http://127.0.0.1:8545, chain ID 31337, EVM target paris.
Alat dan versi	Solidity (solc) 0.8.24, optimizer 200 runs; Hardhat 2.22.17; ethers 6.13.4; hardhat-chai-matchers 2.0.8; chai 4.5.0; solidity-coverage 0.8.14; Slither 0.11.6; Graphviz (diagram).
Repositori / commit	Commit 1caf3a8 (versi awal), 5b6ae73 (PoC eksploit), 713466f (perbaikan dan retest), 0ebe60b (deploy, integrasi, frontend). [Isi tautan repositori]

Komponen	Keterangan / rujukan
Artefak awal	Architecture_Diagram.png, Alur_Transaksi.png, deployments/localhost.json, deployments/localhost-interaction.json, docs/evidence/*.
Langkah reproduksi	npm install --legacy-peer-deps, npx hardhat compile, npx hardhat test, npx hardhat node (terminal 1), lalu npx hardhat run scripts/deploy.js --network localhost dan scripts/interact.js. Rincian ada di README.md.

3 Catatan Pelaksanaan

Tanggal/tahap	Kegiatan yang dilakukan	Hasil dan rujukan bukti
Tahap 1 – Analisis & desain	Menentukan aktor, aset, alur transaksi, kebutuhan trust, pembagian data on-chain/off-chain, dan diagram arsitektur.	B-01, B-02
Tahap 2 – Implementasi	Menulis interface, library, modul RBAC, kontrak v2, dan baseline rentan V1; kompilasi dengan solc 0.8.24.	B-03
Tahap 3 – Unit testing	Menjalankan 31 unit test V2 (positif, negatif, batas, akses) dan mengukur coverage.	B-04, B-05
Tahap 4 – Debugging	Mereproduksi dan memperbaiki dua kesalahan kompilasi terkontrol (titik koma dan konversi tipe).	B-06
Tahap 5 – Audit	Menyusun threat model, PoC eksploit V1 (6 PoC), dan analisis statis Slither.	B-04, B-07
Tahap 6 – Perbaikan & retest	Menerapkan perbaikan A-01..A-07 pada V2 dan menjalankan ulang tes verifikasi.	B-04, B-07
Tahap 7 – Deployment	Menjalankan Hardhat node, deploy CertiChain, mencatat address dan transaction hash.	B-08, B-11
Tahap 8 – Integrasi client	Menjalankan scripts/interact.js: stake, approve, issue, verify, revoke, verify, query event.	B-09
Tahap 9 – Dokumentasi	Menyusun README, laporan audit, deployment record, slide, dan riwayat commit.	B-10

Setiap bukti diberi kode B-01, B-02, dan seterusnya. Pemetaan kode ke berkas ada di Lampiran. Bukti tidak memuat private key, seed phrase, token akses, atau kredensial; akun yang tampil adalah akun uji bawaan Hardhat yang kuncinya memang publik.

4 Bagian Khusus UAS

4.1 Desain solusi dan smart contract (Project 1)

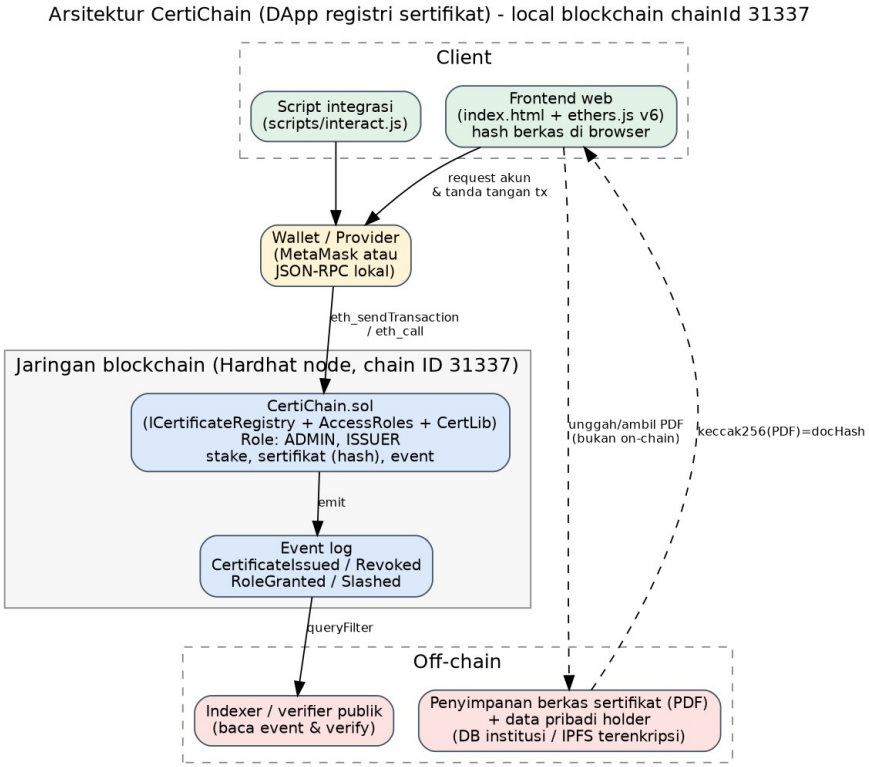
Ada lima pihak dalam sistem. Admin mengatur peran dan sanksi. Issuer adalah institusi penerbit yang menerbitkan dan mencabut sertifikat. Holder adalah penerima sertifikat. Verifier, misalnya pemberi kerja atau kampus lain, memeriksa keaslian sertifikat. Auditor atau regulator menelusuri riwayat lewat event.

Aset yang dilindungi adalah hash dokumen beserta statusnya, stake issuer dalam ETH uji, peran ADMIN dan ISSUER, serta log event sebagai jejak audit.

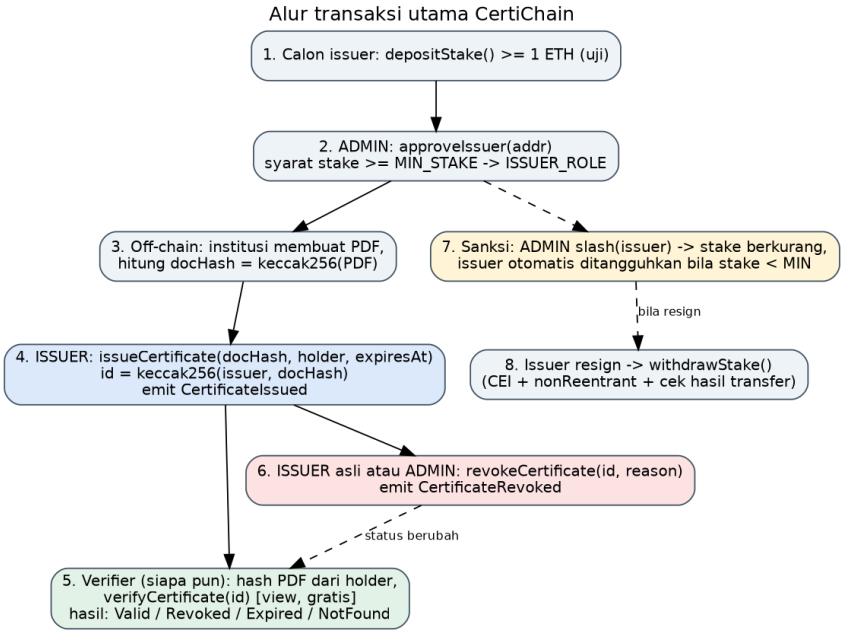
Karena penerbitnya banyak dan tidak saling percaya, mereka membutuhkan catatan bersama yang tidak bisa diubah diam-diam, urutan kejadian yang dapat diaudit, dan verifikasi tanpa harus meminta izin ke penerbit. Kejujuran issuer dijaga dengan stake: issuer yang menyalahgunakan wewenang dapat dikenai slash dan ditangguhkan.

Alur transaksi dan arsitektur

Alur transaksi ditunjukkan pada Gambar 2. Calon issuer menyetor stake, admin menyetujuinya, lalu issuer menghitung hash dokumen di luar rantai dan menerbitkan sertifikat. Siapa pun dapat memverifikasi sertifikat tanpa biaya. Jika ada kesalahan, issuer asli atau admin dapat mencabut sertifikat. Issuer yang melanggar dapat dikenai slash, sedangkan issuer yang berhenti dapat menarik stake-nya.



Gambar 1. Arsitektur frontend, wallet/provider, smart contract, jaringan, dan komponen off-chain (B-01)



Gambar 2. Alur transaksi utama CertiChain (B-02)

Fitur Solidity yang dipakai

- Function dengan visibility external, public, private, dan internal.
- Struct Certificate yang dipadatkan ke tiga slot storage, enum Status, serta mapping dan array dinamis.
- Modifier onlyRole, whenNotPaused, dan nonReentrant.
- Event untuk setiap perubahan state penting.
- Inheritance (CertiChain mewarisi ICertificateRegistry dan AccessRoles), interface, dan library CertLib.
- Custom error dengan revert, fungsi payable, dan pengiriman ETH dengan low-level call yang hasilnya diperiksa.
- Kontrol akses berbasis peran yang ditulis sendiri. Untuk produksi, OpenZeppelin AccessControl lebih disarankan.

Pembagian data dan fungsi utama dirangkum pada tabel berikut.

Data / fungsi	On-chain atau off-chain	Aktor / hak akses	Alasan teknis
Hash dokumen (docHash)	On-chain	Issuer menulis; publik membaca	Hash 32 byte cukup untuk membuktikan integritas, murah, dan tidak membuka isi dokumen.
Berkas PDF dan data pribadi (nama, NIM, nilai)	Off-chain	Institusi dan holder	Privasi dan ukuran data; blockchain tidak dapat menghapus data (hak penghapusan).
Status sertifikat, issuer, holder, issuedAt, expiresAt	On-chain	Status diubah issuer asli atau ADMIN	Status harus tepercaya publik dan tidak dapat diubah pihak lain (A-02).

Data / fungsi	On-chain atau off-chain	Aktor / hak akses	Alasan teknis
Event CertificateIssued / CertificateRevoked	On-chain (log)	Publik membaca	Audit trail murah dan mudah di-index (queryFilter).
Peran ADMIN dan ISSUER	On-chain	ADMIN mengelola	Penegakan akses tidak dapat dilewati; admin terakhir tidak dapat dicabut (LastAdmin).
Stake issuer (ETH uji)	On-chain	Issuer deposit/tarik setelah resign; ADMIN slash	Insentif ekonomi; penarikan memakai CEI + nonReentrant (A-01, A-07).
verifyCertificate(id)	On-chain view	Siapa pun	Pembacaan gratis (eth_call); status Expired dihitung otomatis dari waktu blok.
revokeBatch / getHolderCertificates	On-chain	Issuer asli atau ADMIN / publik	Dibatasi 50 item dan berpaginasi untuk mencegah DoS gas (A-04).

Keputusan desain dan trade-off

- Hanya hash yang disimpan on-chain. Privasi dan biaya terjaga, tetapi ketersediaan berkas bergantung pada penyimpanan di luar rantai, dan hash dari data yang mudah ditebak bisa dibongkar, sehingga perlu salt acak.
- ID sertifikat dibentuk dari keccak256(issuer, docHash) agar hash tidak bisa diserobot issuer lain (A-03). Konsekuensinya, hash yang sama dari dua issuer menjadi dua catatan terpisah.
- Stake wajib 1 ETH uji menambah akuntabilitas, tetapi menambah hambatan masuk dan kerumitan penarikan.
- Pencabutan tetap diizinkan saat kontrak di-pause, karena keamanan lebih penting daripada kelancaran penerbitan.
- Kontrak tidak dapat di-upgrade. Ini lebih mudah diaudit dan bebas risiko proxy, tetapi perubahan aturan berarti deploy ulang dan migrasi.
- Admin hanya satu pada prototipe. Sederhana, tetapi menjadi titik sentral, sehingga produksi memerlukan multisig dan timelock.

4.2 Pengujian, deployment, dan integrasi (Project 2)

ID tes	Skenario positif/negatif/batas/akses	Ekspektasi	Hasil	Bukti
T-01	[positif] Deployment: admin awal, adminCount, konstanta	Admin terdaftar, adminCount=1, MIN_STAKE=1 ETH, MAX_BATCH=50	Lulus	B-04
T-02	[negatif] Deploy dengan admin address(0)	Revert ZeroAddress	Lulus	B-04
T-03	[akses] Non-admin memanggil approveIssuer/setPaused/slash/grantAdmin	Revert NotAuthorized pada keempatnya	Lulus	B-04
T-04	[positif/batas] Tambah admin kedua, cabut admin pertama, cabut admin terakhir	Dua admin diizinkan; admin terakhir revert LastAdmin	Lulus	B-04
T-05	[batas] grantAdmin(address(0))	Revert ZeroAddress	Lulus	B-04
T-06	[batas] approveIssuer dengan stake MIN_STAKE−1 wei lalu tepat MIN_STAKE	Gagal StakeTooLow lalu berhasil; peran ISSUER diberikan	Lulus	B-04

ID tes	Skenario positif/negatif/batas/akses	Ekspektasi	Hasil	Bukti
T-07	[negatif] depositStake bernilai 0	Revert ZeroValue	Lulus	B-04
T-08	[positif/akses] Issuer aktif tarik stake; setelah resign tarik stake	Revert StillIssuer; setelah resign saldo +1 ETH, stake 0	Lulus	B-04
T-09	[negatif] withdrawStake tanpa stake	Revert NoStake	Lulus	B-04
T-10	[positif] slash 0,5 ETH lalu withdrawSlashed	Stake berkurang, issuer ditangguhkan otomatis, slashedPool dapat ditarik, penarikan kedua revert	Lulus	B-04
T-11	[batas] slash melebihi stake; withdrawSlashed ke address(0)	Revert InsufficientStake; revert ZeroAddress	Lulus	B-04
T-12	[akses] Issuer yang ditangguhkan menerbitkan sertifikat	Revert NotAuthorized	Lulus	B-04
T-13	[positif] Issuer menerbitkan sertifikat	Event CertificateIssued benar; state Valid; hitungan holder=1	Lulus	B-04
T-14	[akses] Non-issuer dan admin menerbitkan	Revert NotAuthorized	Lulus	B-04
T-15	[negatif] docHash=0 dan holder=address(0)	Revert InvalidHash dan ZeroAddress	Lulus	B-04
T-16	[batas] expiresAt = waktu blok, waktu blok+1, dan 0	Sama dengan waktu blok revert InvalidExpiry; +1 dan 0 diterima	Lulus	B-04
T-17	[negatif] Penerbitan ganda hash yang sama oleh issuer yang sama	Revert AlreadyIssued	Lulus	B-04
T-18	[negatif/ordering] Issuer B menerbitkan hash sama lebih dulu (simulasi front-run)	Penerbitan A tetap berhasil; dua ID berbeda dengan holder masing-masing	Lulus	B-04
T-19	[positif/akses] Pause menghentikan penerbitan, unpause memulihkan	Penerbitan revert Paused saat pause; pencabutan tetap berhasil	Lulus	B-04
T-20	[negatif] Verifikasi ID tak dikenal	Status NotFound	Lulus	B-04
T-21	[batas] Status pada expiresAt−1 dan tepat expiresAt	Valid lalu Expired	Lulus	B-04
T-22	[positif] Issuer asli mencabut	Event CertificateRevoked benar; status Revoked	Lulus	B-04
T-23	[akses] ADMIN mencabut sertifikat issuer lain	Berhasil; status Revoked	Lulus	B-04
T-24	[akses] Issuer lain dan pihak luar mencabut	Revert NotAuthorized; status tetap Valid	Lulus	B-04
T-25	[negatif] Cabut dua kali; cabut ID tak ada	Revert AlreadyRevoked; revert CertNotFound	Lulus	B-04
T-26	[positif] Issuer yang sudah resign mencabut sertifikat miliknya	Berhasil; status Revoked	Lulus	B-04
T-27	[batas] revokeBatch 51 item lalu 50 item	51 revert BatchTooLarge; 50 berhasil	Lulus	B-04
T-28	[akses] Batch memuat sertifikat issuer lain	Seluruh transaksi revert (atomik); status tetap Valid	Lulus	B-04
T-29	[batas] Paginasi offset/limit/di luar rentang	Halaman sesuai; di luar rentang menghasilkan array kosong	Lulus	B-04
T-30	[negatif/keamanan] Serangan reentrancy pada withdrawStake	Revert TransferFailed; saldo kontrak tetap 2 ETH	Lulus	B-04
T-31	[negatif/keamanan] Penarikan ke kontrak penolak ETH	Revert TransferFailed; stake tetap 1 ETH	Lulus	B-04

Seluruh 37 tes lulus: 31 unit test pada tabel di atas dan 6 PoC eksploit yang dibahas pada subbab 4.3. Coverage CertiChain.sol adalah 100% statement, 90% branch, 100% function, dan 100% line (B-05). Skenario positif, negatif, batas, dan kontrol akses sudah tercakup.

Kasus debugging

Untuk latihan debugging, penulis membuat berkas docs/debug/Broken.sol yang berisi dua kesalahan umum. Percobaan pertama gagal karena titik koma hilang. Setelah diperbaiki, percobaan kedua gagal karena uint256 tidak bisa dikonversi secara implisit ke uint64. Percobaan ketiga berhasil setelah memakai

cast eksplisit uint64(expiresAt) (B-06). Compiler juga memberi peringatan bahwa return value low-level call tidak digunakan pada CertiChainV1 (B-03). Peringatan ini kemudian terbukti sebagai temuan A-07.

```
Percobaan 1: Error: Expected ';' but got 'return'  --> Broken.sol:9:9
Percobaan 2: Error: Type uint256 is not implicitly convertible to expected type uint64.  -->
Fixed_step1.sol:7:9
Percobaan 3: Compiler run successful.
```

Compile dan deployment

Kompilasi memakai npx hardhat compile dengan solc 0.8.24, dan 7 berkas berhasil dikompilasi. Deployment dilakukan setelah menjalankan npx hardhat node, lalu npx hardhat run scripts/deploy.js --network localhost. Jaringannya localhost dengan chain ID 31337. Contract address 0x5FbDB2315678afecb367f032d93F642f64180aa3, hash transaksi deployment 0x9845613a2f700b5d4ebe9708c6ac243b8cec9666d2a26506df2cf1d0410429de, block 1, gas 1.515.744. Deployer sekaligus admin awal adalah akun uji Hardhat #0 (B-08).

Integrasi client

Skrip scripts/interact.js terhubung ke node lokal lewat provider ethers. Urutan transaksinya: depositStake (0x32eba769…05d821, block 2), approveIssuer (0xd4b290a2…3000, block 3), issueCertificate (0xeca5fb48… 5013, block 4, gas 141.450), verifyCertificate yang menghasilkan Valid, revokeCertificate (0x4d2fffe3…2660, block 5, gas 29.613), lalu verifyCertificate yang menghasilkan Revoked. Pencarian log dengan queryFilter menemukan satu event CertificateIssued dan satu CertificateRevoked untuk ID yang sama (B-09). Hash lengkap ada di Deployment_Record.pdf.

Frontend ada di frontend/index.html. Halaman ini menghitung hash berkas di peramban, memverifikasi sertifikat, serta menerbitkan dan mencabut lewat wallet atau provider. Frontend belum diuji otomatis di peramban dengan MetaMask, jadi jalur integrasi yang terbukti berjalan adalah skrip interact.js. Langkah instalasi dan reproduksi ada di README.md.

4.3 Audit keamanan dan perbaikan (Project 3)

Threat model

Aset yang dilindungi adalah integritas catatan sertifikat, dana stake issuer, peran ADMIN dan ISSUER, serta ketersediaan fungsi verifikasi dan pencabutan. Aktornya adalah admin, issuer jujur dan jahat, holder, verifier, penyerang eksternal (akun biasa atau kontrak), serta block builder yang dapat mengatur urutan transaksi.

Trust boundary ada di lima titik: antara data di luar rantai dan di dalam rantai (isi PDF tidak dipercaya), antara wallet dan kontrak, antara kontrak dan penerima ETH, antara admin dan issuer, serta mempool publik. Skenario penyalahgunaan yang dipertimbangkan adalah pengurasan stake lewat reentrancy, pencabutan sertifikat pesaing, penyerobotan hash, spam yang menggagalkan pencabutan massal, input sampah, dana terkunci karena transfer gagal, dan manipulasi waktu blok.

ID temuan	Bukti dan dampak	Kemungkinan / risiko	Perbaikan / commit	Retest dan status
A-01 Reentrancy	withdrawStake V1 mengirim ETH sebelum stake dinolkan. PoC: setor 1 ETH, akhir 3 ETH; kontrak 0 ETH; Slither reentrancy-eth. Dampak: tinggi.	Kemungkinan tinggi Risiko TINGGI	CEI + nonReentrant (CertiChain.sol, commit 713466f).	T-30 lulus: revert TransferFailed, saldo kontrak 2 ETH. Slither V2 tanpa reentrancy. TERVERIFIKASI

ID temuan	Bukti dan dampak	Kemungkinan / risiko	Perbaikan / commit	Retest dan status
A-02 Access control	revokeCertificate V1 hanya memeriksa ISSUER_ROLE; issuer B mencabut sertifikat issuer A (PoC). Dampak: tinggi.	Kemungkinan sedang Risiko TINGGI	Hanya issuer asli atau ADMIN; selain itu NotAuthorized (713466f).	T-24 dan T-28 lulus. TERVERIFIKASI
A-03 Transaction ordering	ID V1 = docHash; issuer B menyerobot hash, holder salah, penerbitan A revert (PoC). Dampak: sedang.	Kemungkinan sedang Risiko SEDANG	ID = keccak256(issuer, docHash) via CertLib.computeId (713466f).	T-18 lulus: dua ID berbeda. TERVERIFIKASI
A-04 DoS loop	revokeAllForHolder V1 tak terbatas. PoC: 125.165 gas (10 sert.) vs 2.000.477 (200 sert.); ±9.870 gas/sert.; ±3.039 sert. melampaui blok 30 M gas. Dampak: sedang.	Kemungkinan sedang Risiko SEDANG	revokeBatch maksimum 50 item; getHolderCertificates berpaginasi (713466f).	T-27 dan T-29 lulus. TERVERIFIKASI
A-05 Validasi input	V1 menerima holder=0, hash=0, dan expiry masa lalu (PoC). Dampak: rendah.	Kemungkinan tinggi Risiko RENDAH	Custom error InvalidHash, ZeroAddress, InvalidExpiry (713466f).	T-15 dan T-16 lulus (batas timestamp). TERVERIFIKASI
A-06 Oracle / timestamp	Tidak ada oracle; kedaluwarsa memakai block.timestamp (Slither: timestamp). Dampak: rendah.	Kemungkinan rendah INFORMASIONAL	Diterima: toleransi detik tidak relevan untuk masa berlaku hari/tahun.	T-21 menguji batas. DICATAT, DITERIMA
A-07 Error handling	Hasil low-level call V1 tidak diperiksa: stake dinolkan walau transfer gagal, 1 ETH terkunci (PoC; Slither unchecked-lowlevel). Dampak: tinggi.	Kemungkinan rendah Risiko SEDANG	if (!ok) revert TransferFailed() sehingga seluruh transaksi dibatalkan (713466f).	T-31 lulus: stake tetap 1 ETH. TERVERIFIKASI

Tabel audit temuan

Klasifikasi dan analisis statis

Tingkat risiko ditentukan dari dampak dan kemungkinan eksploitasi. Dampak tinggi dengan kemungkinan sedang atau tinggi dinilai berisiko tinggi (A-01, A-02), sedangkan dampak tinggi dengan kemungkinan rendah dinilai sedang (A-07). Slither menjalankan 102 detektor pada 9 kontrak dan menghasilkan 10 temuan. Temuan reentrancy-eth dan unchecked-lowlevel hanya muncul pada V1, sehingga mengonfirmasi A-01 dan A-07. Pada V2 tersisa peringatan arbitrary-send-eth pada withdrawSlashed, timestamp, dan low-level-calls (B-07). Peringatan pertama diterima karena fungsinya hanya dapat dipanggil ADMIN, tujuan dana ditentukan tata kelola, dan fungsi itu dilindungi nonReentrant.

Perubahan kode

Dari V1 ke V2 (commit 1caf3a8 ke 713466f), withdrawStake diubah agar saldo dinolkan sebelum ETH dikirim dan diberi guard reentrancy. Pencabutan sertifikat kini hanya boleh dilakukan issuer asli atau admin. ID sertifikat terikat pada issuer, input divalidasi, pencabutan massal dibatasi 50 item, dan daftar sertifikat per holder dibaca per halaman. Penulis juga menambahkan slash, perlindungan admin terakhir, dan pause.

V1 sengaja dibuat rentan (vulnerable-by-design) supaya efektivitas perbaikan dapat dibuktikan dengan PoC sebelum dan retest sesudahnya. Laporan audit lengkap ada di Security_Audit.pdf.

Audit ini dilakukan sendiri tanpa fuzzing atau verifikasi formal. Invariant seperti total stake sama dengan saldo kontrak dikurangi slashedPool dapat diuji dengan Echidna atau Foundry pada tahap lanjut, dan audit independen tetap disarankan sebelum kontrak dipakai di dunia nyata.

4.4 Enterprise, privasi, dan nonfungsional (Project 4)

Aspek	Public/Ethereum	Permissioned/Fabric	Keputusan untuk kasus
Identitas dan izin	Pseudonim (alamat); siapa pun dapat membuat akun; izin diterapkan di level kontrak (RBAC) sehingga identitas legal issuer harus diikat secara off-chain.	Identitas tersertifikasi (MSP/CA); hanya peserta terdaftar yang dapat bergabung dan mengirim transaksi.	Permissioned: issuer adalah institusi yang dikenal; identitas dan izin adalah kebutuhan inti.
Konsensus dan throughput	Proof of Stake pada L1; throughput terbatas dan finality dalam hitungan menit; L2 dapat meningkatkan kapasitas.	Ordering service (Raft/CFT; BFT pada rilis lebih baru); sering dilaporkan mencapai ribuan TPS pada benchmark terkontrol, bergantung konfigurasi.	Beban penerbitan sertifikat rendah-menengah; keduanya memadai, permissioned lebih dapat diprediksi.
Privasi dan biaya	Data transparan bagi semua node; biaya gas per transaksi dan fluktuatif; privasi perlu teknik tambahan (hash, zero-knowledge).	Channel dan private data collection membatasi visibilitas; tanpa gas, biaya berupa operasi node dan konsorsium.	Permissioned unggul untuk privasi dan biaya terprediksi; hash-only tetap dipertahankan.
Governance dan upgrade	Tata kelola jaringan oleh komunitas; kontrak immutable atau proxy; kontrol admin/multisig ada pada pemilik kontrak.	Kebijakan konsorsium (channel policy, chaincode lifecycle dengan persetujuan organisasi) dan penyelesaian sengketa tertulis.	Konsorsium perguruan tinggi memerlukan governance formal; public chain tidak memberi mekanisme sengketa.
Skalabilitas dan interoperabilitas	Ekosistem besar, standar EVM/ERC, tooling matang; integrasi lintas chain melalui bridge (risiko tambahan).	Interoperabilitas via API/gateway dan standar identitas; ekosistem lebih kecil; chaincode bukan Solidity.	EVM-compatible permissioned (mis. Hyperledger Besu) mempertahankan kode Solidity dan tooling.

Skalabilitas dan bottleneck

Beban CertiChain didominasi pembacaan untuk verifikasi, yang gratis karena memakai eth_call dan tidak membebani konsensus. Penulisan hanya terjadi saat penerbitan dan pencabutan. Bottleneck utamanya ada empat: antrean dan biaya transaksi di public L1 ketika penerbitan massal, misalnya saat wisuda; array sertifikat per holder yang terus tumbuh (diatasi dengan paginasi, A-04); ketersediaan penyimpanan di luar rantai; dan kebutuhan indexer untuk pencarian yang lebih kaya daripada pembacaan per ID. Kapasitas dapat dinaikkan dengan batching, penerbitan lewat Merkle root, atau L2.

Interoperabilitas

Kontrak mengikuti standar EVM sehingga dapat dipindahkan ke jaringan EVM lain, publik maupun permissioned. Antarinstitusi perlu menyepakati format dokumen, algoritma hash, dan skema ID. Untuk lintas chain, gateway atau anchoring lebih tepat daripada bridge aset.

Privasi data

Nama, NIM atau NIK, nilai, alamat, isi PDF, dan data pribadi lain tidak boleh diletakkan di blockchain. Data on-chain tidak dapat dihapus dan terbuka bagi semua node, padahal UU Pelindungan Data Pribadi (UU 27/2022) mengatur hak subjek data. Hash dari data yang mudah ditebak dapat dibongkar dengan brute force, sehingga hash sebaiknya dihitung dari dokumen yang diberi salt acak. Alamat holder bersifat pseudonim tetapi dapat ditautkan, jadi alamat per sertifikat atau pencatatan holder dalam bentuk hash patut dipertimbangkan.

Tata kelola

Pada prototipe, admin mengelola peran, sanksi, dan pause. Mengubah kontrak berarti deploy kontrak baru karena kontrak tidak dapat di-upgrade. Untuk produksi, admin sebaiknya berupa multisig konsorsium dengan timelock, sementara penambahan dan penghapusan node diputuskan konsorsium. Sengketa, misalnya issuer yang dituduh mencabut sertifikat tanpa dasar, diselesaikan komite konsorsium dengan bukti event on-chain, dan slash hanya dijalankan dengan persetujuan beberapa pihak.

Kapan pilihan lain lebih tepat

Public blockchain cocok bila verifikasi harus netral tanpa operator tepercaya, pesertanya tidak dikenal, dan datanya memang publik. Blockchain permissioned cocok bila pesertanya dikenal, privasi dan tata kelola formal dibutuhkan, dan biaya harus bisa diperkirakan. Database tradisional dengan tanda tangan digital lebih tepat bila hanya ada satu penerbit tepercaya, tidak perlu jejak lintas pihak, atau data harus bisa dihapus. Pada kondisi itu blockchain tidak menambah nilai.

Rekomendasi arsitektur akhir

Penulis merekomendasikan blockchain permissioned berbasis EVM, misalnya Hyperledger Besu dengan QBFT, yang dioperasikan konsorsium institusi penerbit. Kontrak tetap Solidity, hanya hash bersalt yang dicatat on-chain, berkas disimpan terenkripsi di luar rantai, dan verifikasi publik disediakan lewat gateway read-only. Merkle root dapat dijangkarkan berkala ke public chain bila perlu transparansi tambahan. Alasannya, penerbit dikenal, privasi dan tata kelola formal dibutuhkan, biaya lebih mudah diperkirakan, dan kode serta tes prototipe dapat dipakai ulang. Perbandingan ini bersifat kualitatif, sehingga angka throughput dan biaya masih perlu diukur di lingkungan konsorsium yang sebenarnya.

4.5 Showcase dan kontribusi (Project 5)

Demo berjalan dengan urutan berikut: menjalankan Hardhat node, deploy kontrak dan mencatat address serta hash transaksi, stake dan approve issuer, menerbitkan sertifikat dari hash dokumen, verifikasi (Valid), pencabutan, verifikasi ulang (Revoked), lalu menampilkan event di log. Setelah itu ditunjukkan 37 tes lulus, coverage, PoC pada V1, dan retest pada V2. Presentasi terdiri dari 7 slide (Slide_Presentasi.pptx), dan skenario video cadangan ada di docs/Skenario_Video_Demo.md.

Etika, regulasi, dan dampak

Prototipe hanya berjalan di local network dengan data simulasi. Bila dipakai di dunia nyata, perlu dipertimbangkan UU Pelindungan Data Pribadi (UU 27/2022), aturan tanda tangan dan sertifikat elektronik (UU ITE dan PP 71/2019), serta ketentuan penerbitan ijazah dari kementerian terkait. Ketentuan ini perlu dicek ulang ke sumber resminya.

Risiko yang ada adalah kunci issuer bocor, tata kelola yang terpusat pada admin, dan institusi kecil yang kesulitan ikut serta. Manfaatnya adalah verifikasi yang cepat dan murah serta berkurangnya pemalsuan. Agar berkelanjutan, diperlukan operasi node konsorsium, rotasi kunci, dan prosedur pencabutan yang adil.

Roadmap perbaikan

- Admin berupa multisig dengan timelock.
- Fuzzing, invariant testing, dan audit eksternal.
- Pengujian otomatis untuk frontend.
- Hash bersalt dan penyimpanan terenkripsi di luar rantai.
- Migrasi ke jaringan konsorsium EVM disertai uji beban.
- Indexer untuk pencarian dan integrasi identitas issuer (DID atau PKI).

Anggota	Tugas/kontribusi	Commit / bukti	Bagian yang dipresentasikan
[Isi nama]	Dikerjakan individu: desain, kontrak, pengujian, audit, deployment, dan dokumentasi	[Isi commit dari git log repositori]	Seluruh slide

UAS ini dikerjakan secara individu, sehingga seluruh bagian menjadi tanggung jawab penulis.

5 Kesimpulan, Daftar Pustaka, dan Lampiran

Kesimpulan: Kontrak CertiChain v2 layak sebagai prototipe. Alur dari stake sampai pencabutan berjalan di local network, 37 tes lulus, dan coverage fungsi inti mencapai 100%. Dari tujuh temuan audit, enam diperbaiki dan terbukti lewat PoC dan retest, sedangkan satu bersifat informasional. Yang sudah terbukti adalah perilaku kontrak di local network serta mitigasi terhadap reentrancy, kelemahan access control, urutan transaksi, DoS, validasi input, dan error handling. Yang masih terbatas adalah audit yang dilakukan sendiri tanpa fuzzing, admin tunggal, frontend yang belum diuji otomatis, dan data yang hanya simulasi. Tindak lanjut yang realistis adalah multisig dengan timelock, fuzzing, audit eksternal, dan migrasi ke jaringan konsorsium EVM sesuai rekomendasi.

Daftar pustaka:

1. Antonopoulos, A. M. dan Wood, G. (2018). Mastering Ethereum. O'Reilly Media.

2. Feist, J., Grieco, G., dan Groce, A. (2019). Slither: A Static Analysis Framework for Smart Contracts. WETSEB 2019.

3. Dokumentasi Solidity. docs.soliditylang.org (diakses Oktober 2026).

4. Dokumentasi Hardhat. hardhat.org.

5. Dokumentasi ethers.js v6. docs.ethers.org/v6.

6. OpenZeppelin Contracts Documentation. docs.openzeppelin.com/contracts.

7. Smart Contract Weakness Classification Registry. swcregistry.io.

8. Hyperledger Fabric Documentation. hyperledger-fabric.readthedocs.io.

9. Hyperledger Besu Documentation. besu.hyperledger.org.

10. Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi.

11. Materi kuliah Blockchain, Universitas Siliwangi, TA 2026/2027.

Seluruh kode kontrak ditulis sendiri oleh penulis. Pola Checks-Effects-Interactions dan reentrancy guard mengikuti praktik umum yang dijelaskan pada dokumentasi di atas.

Lampiran: README.md; kode kontrak (contracts/) dan client (scripts/, frontend/); folder test/ beserta hasilnya; Deployment_Record.pdf; Security_Audit.pdf; Architecture_Diagram.png; Slide_Presentasi.pptx; riwayat commit; dan video cadangan (Video_Demo.mp4). Pemetaan kode bukti:

Kode bukti	Berkas	Keterangan
B-01	docs/Architecture_Diagram.png	Diagram arsitektur
B-02	docs/Alur_Transaksi.png	Diagram alur transaksi
B-03	docs/evidence/B-compile-output.txt	Keluaran kompilasi (peringatan low-level call V1)
B-04	docs/evidence/B-test-output.txt	37 tes lulus termasuk PoC V1 dan log gas
B-05	docs/evidence/B-coverage-output.txt	Laporan coverage
B-06	docs/evidence/B-debug-compile.txt	Debugging kompilasi (3 percobaan)
B-07	docs/evidence/B-slither-all.txt	Keluaran Slither
B-08	docs/evidence/B-deploy-output.txt; docs/Deployment_Record.pdf	Address dan tx hash deployment
B-09	docs/evidence/B-interact-output.txt; deployments/localhost-interaction.json	Interaksi client dan event
B-10	docs/evidence/git-log.txt	Riwayat commit
B-11	docs/evidence/B-node-log.txt	Log node Hardhat lokal